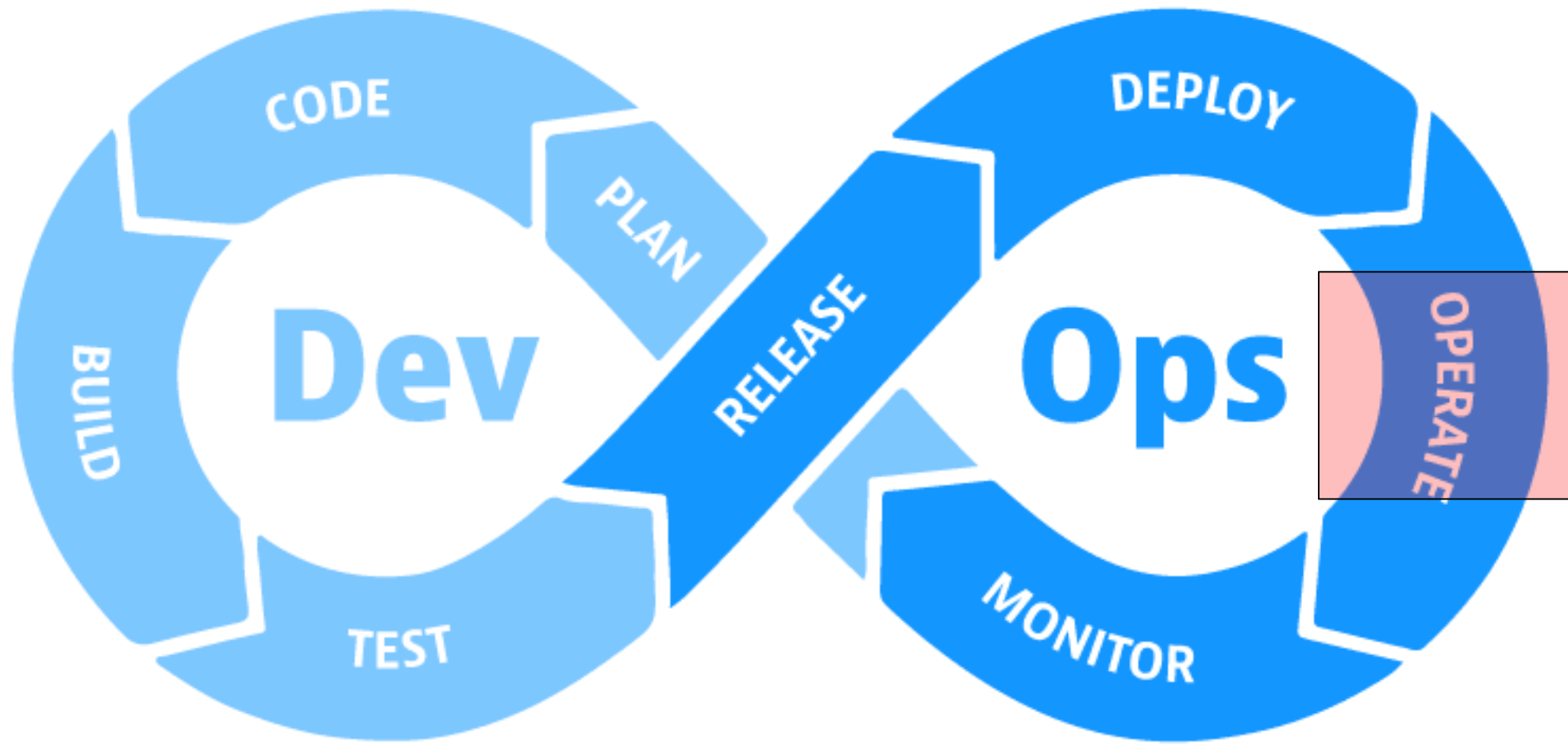


Developer Operations (devops)

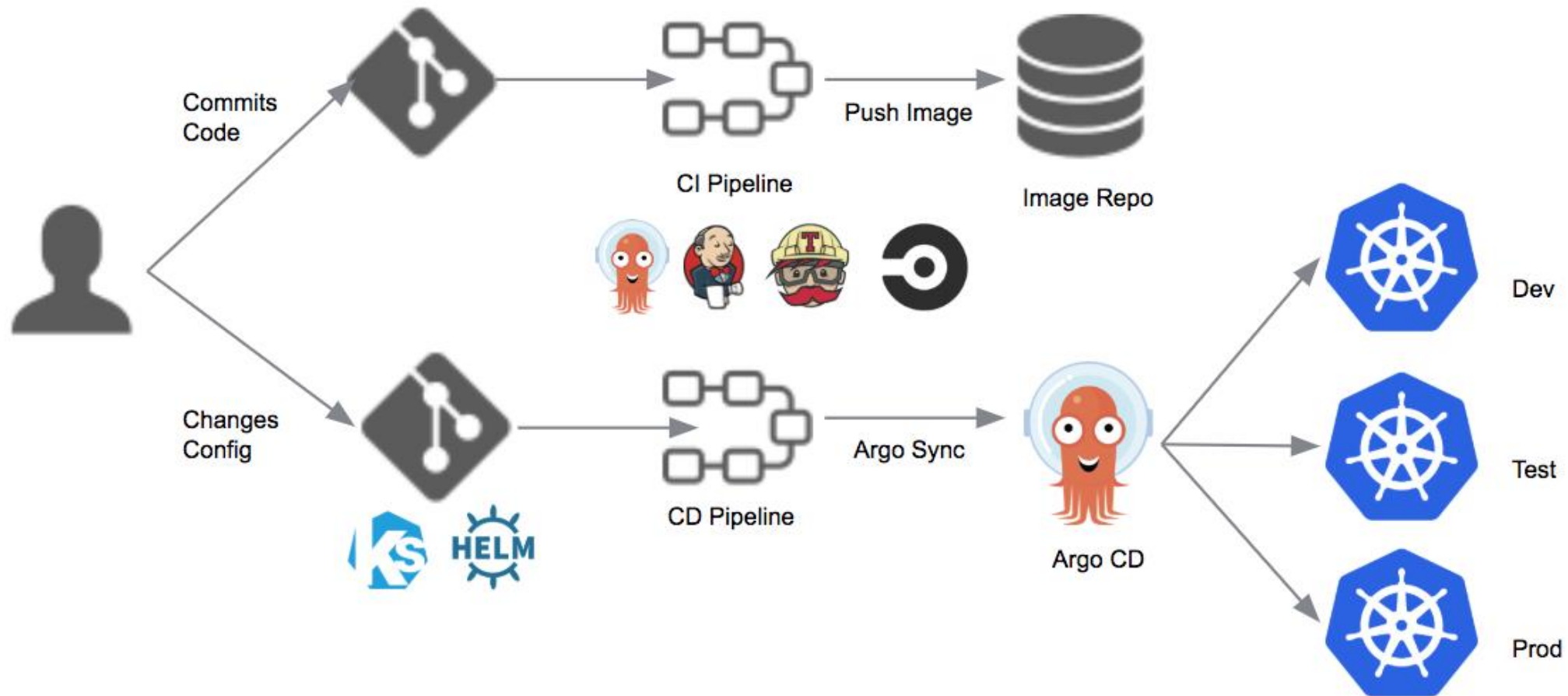
Secret Management



Build and Release



What secrets to you have?



What secrets to you have?

Secret != Secret:

When do you need the secret?

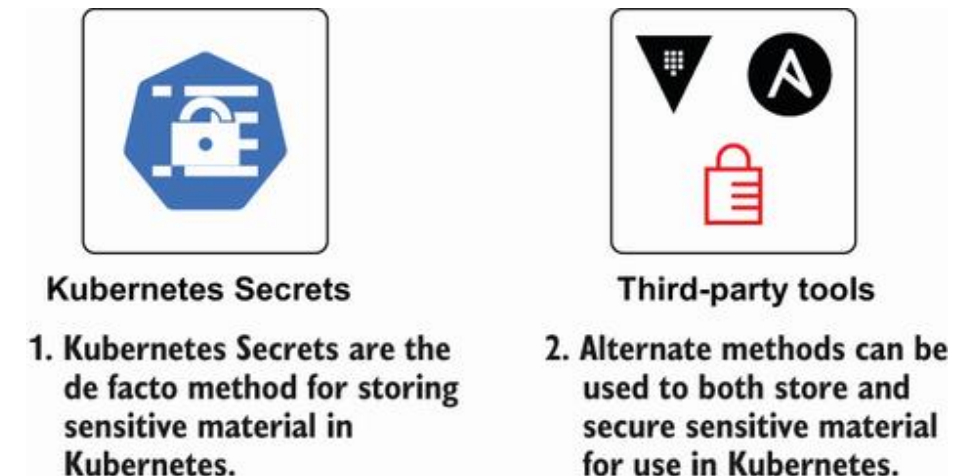
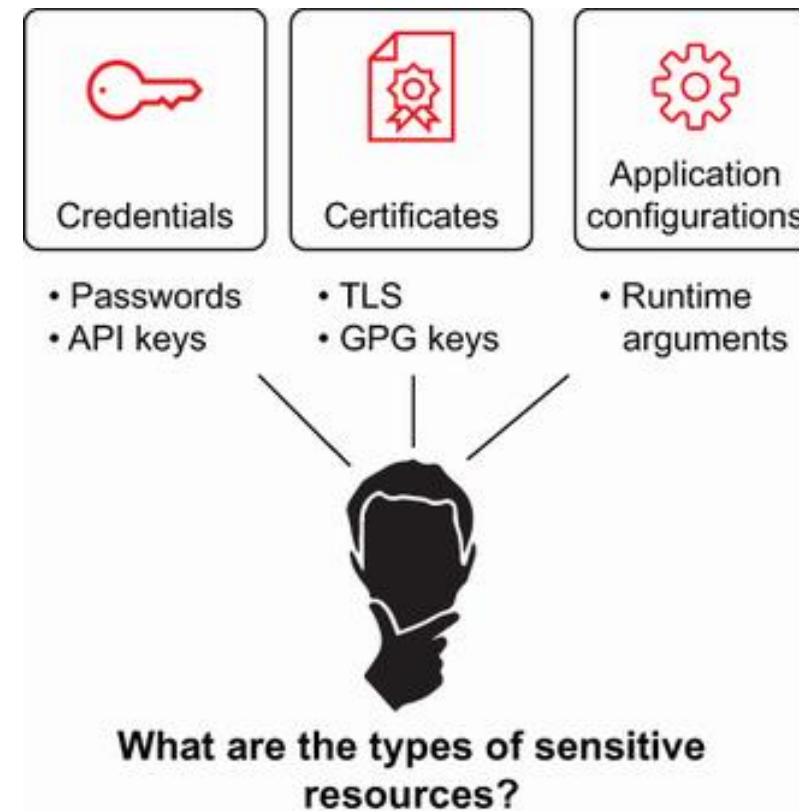
- Runtime?
- Deploytime?

How sensitive is the secret?

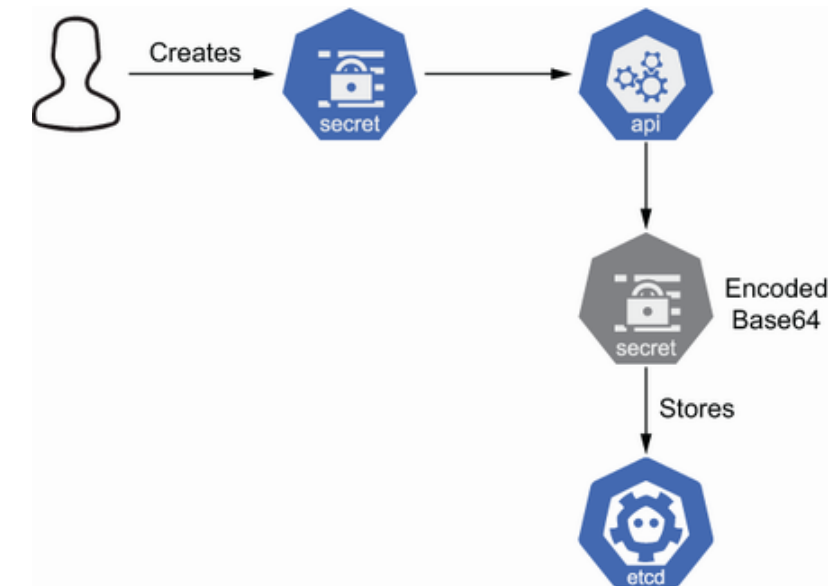
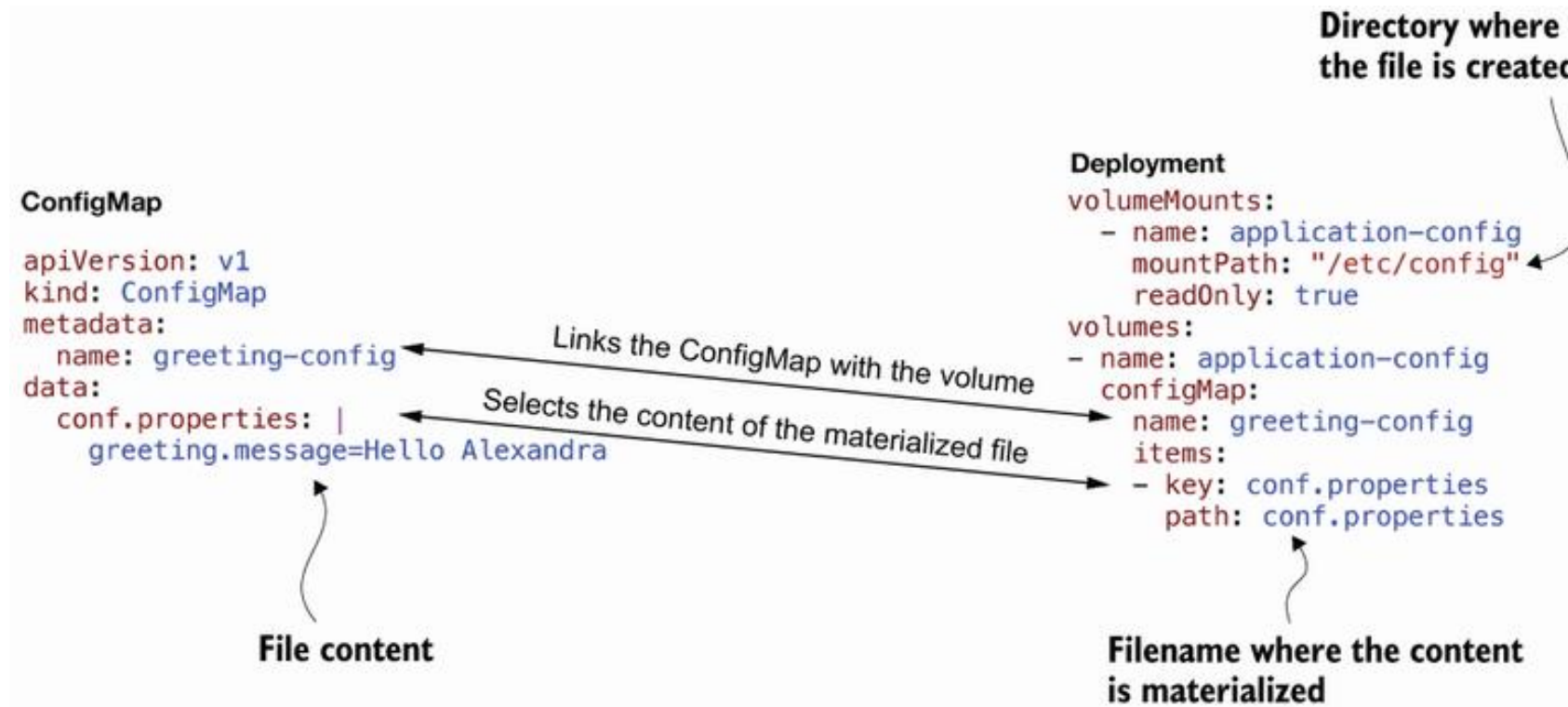
How easy can the secret be rotated/changed?

Where are the secrets needed?

- Platform?
- Build?

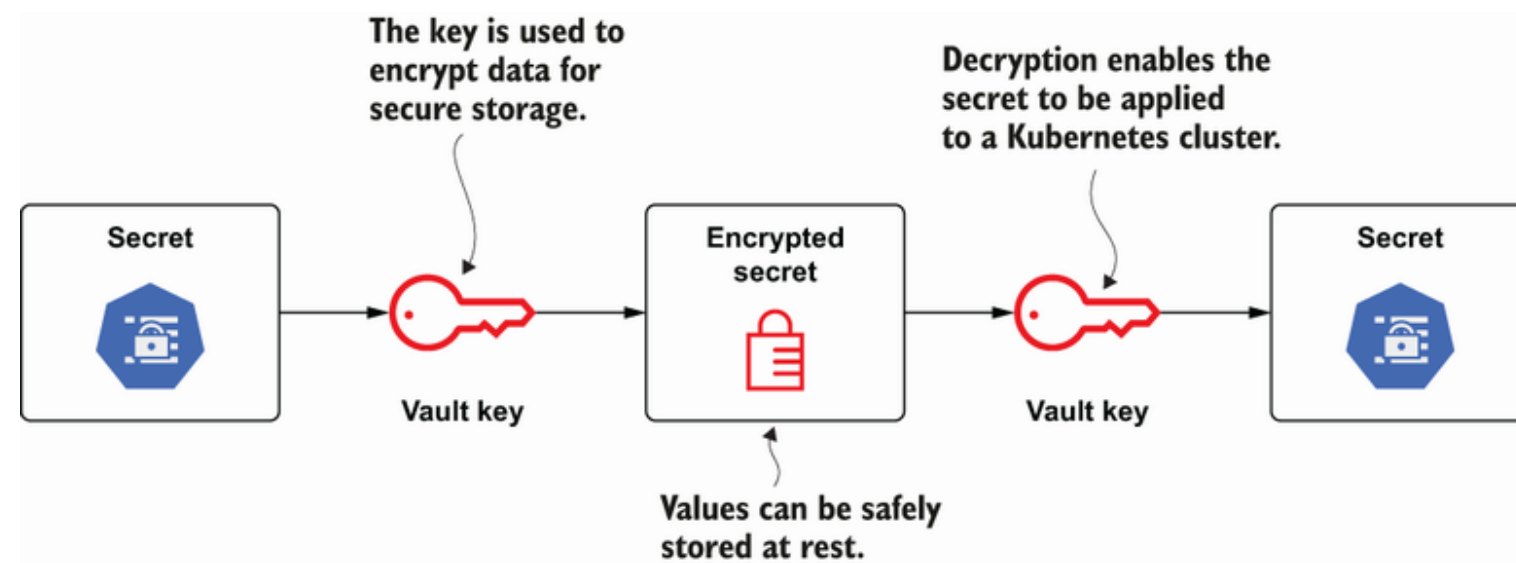


Secrets in K8s?



Handling Confidentiality externally

- Kubernetes is not involved in secret handling
- External tool e.g. `ansible vault`, SOPS necessary
- Working also with different platforms
- Secret is as confidential as K8s (stored decrypted internally)



```
ansible-vault encrypt greeting-secret_ansible.yaml
```

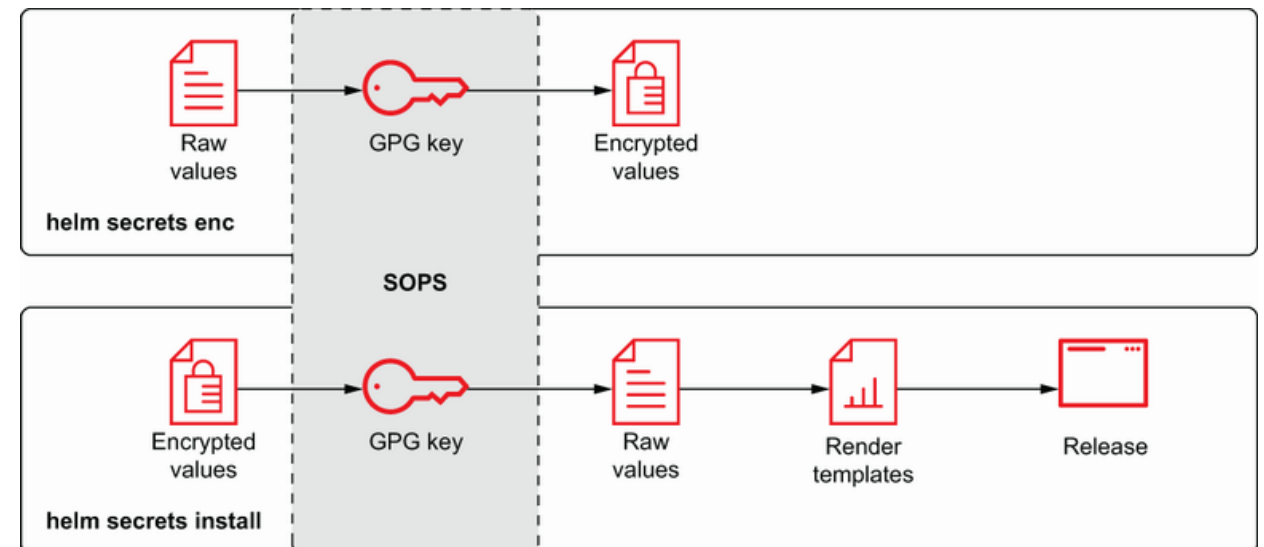
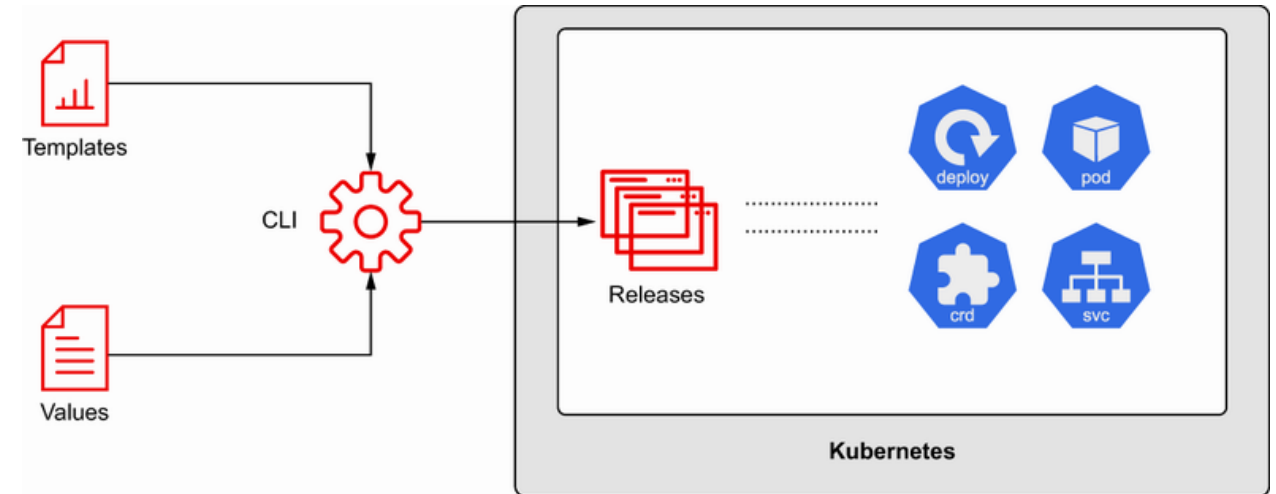
```
New Vault password:
```

```
Confirm New Vault password:
```

```
Encryption successful
```

Handling Confidentiality externally with packaging

- Tools can be part of packing system e.g. `helm secret`
- Needs additional tools such as `gpg`, `SOPS`, etc.
- Can rely on external key management systems e.g. hyperscaler



Handling Confidentiality externally with packaging

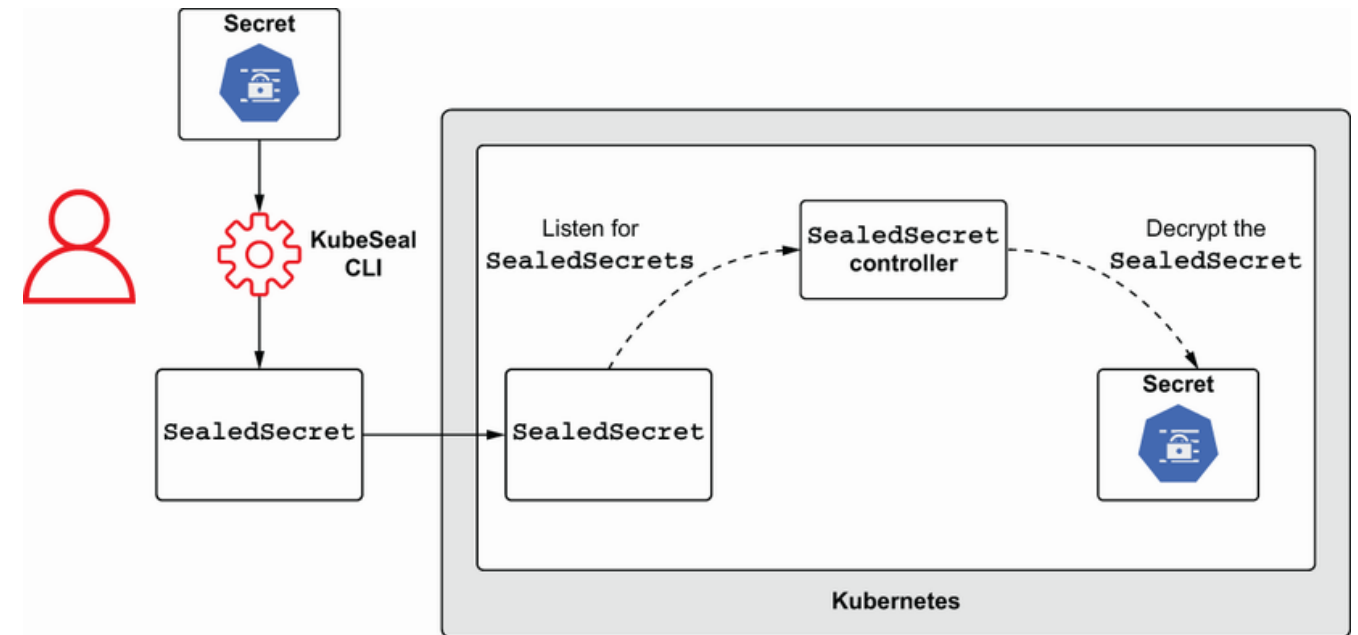
Secret key to decrypt must be present in platform:

- Either in K8s itself
 - The secret key is as confidential as the platform
 - Be aware about platform breaches
- Or by using external accessible stores
 - Be aware about SPOF

```
greeting:
  message: ENC[AES256_GCM,data:SYfMBpax8mTOqzPed3ksjA==,iv:OrN/r/WVF+ROR
    ➔BBaiyqyiRyIRS+LPb3gf2q9gU4OVH8=,tag:
    ➔B9NYch4tNruKzBQMKqk00g==,type:str] ①
sops:
  kms: []
  gcp_kms: []
  azure_kv: []
  hc_vault: []
  lastmodified: '2020-12-31T04:21:40Z'
  mac: ENC[AES256_GCM,data:h2fQPc9hzmGMAkIE73aYU2TxbwVYQQLRcYHWh++kAYjK
    ➔zm+o9KibOcsVXz8iRLVbeER62FR4h2AON6ZC8ZxoWW5MxQm
    ➔w729YOQc1nkrGwxsx+ST2ucYmUxn3D4Kqb9X8NSu8P3fPcr
    ➔/Q77fFQ4SK1fLh2Jd92UZt5dJ6hOGJEr0=,iv:cvXEVhZUP
    ➔9uHbYAASbXL8KS3sso34STMZhpG/phzN4U=,tag:PtCoqDf
    ➔Z4C+KN7Qxz55DSw==,type:str]
  pgp:
    - created_at: '2020-12-31T04:21:39Z'
      enc: |
        -----BEGIN PGP MESSAGE-----
        hQEMA0e7sMUymEkyAQgAhrnbGtCkbRwEDkylTmWTHXeKhoEx+2bbD8vJ+g9m7hYl
        iDwat80MKu2lGKgnVj2RAMixwyjaLdoGY+pDXyxUJ5StFojh1bJbkEYKT5KYaGni
        uvkpeYNwLtAZWd6Shj1l1vAkVEDMsh3xFtv9ot2uwL/DuxmSvoIR5OxpLwEZSAPgM
        Uzsk0SMWQjyIT69oUKlJYd+Nwj0sv1oWJMAkra367EZxKzKKilEKFZ3QHq4JVAqp
        +P8ctjQqeWi8bC/wN6PdRGVYfZD8bF3CvgdtYUKHRseNvjX2H6rD60x15FgADx9v
        bGfOu4n5SccgGftgnYI8nXL7vnAntuLREz6XDnLQDNJeAVzDt623nJmlqKGP+x/G
        HYfaEqBWI8bcPfBwHv3g9F1sAk86W86IR6pB0mOwD/twW9/J7InW91xEz2Q9KhMR
        oWVWwF8IZzNWVb6Sjl6EXIaB+ssJXOtFWXyBD83w8Q==
        =TH/P
        -----END PGP MESSAGE-----
      fp: 53696D1AB6954C043FCBA478A23998F0CBF2A552 ②
  unencrypted_suffix: _unencrypted
  version: 3.6.1
```

Handling Confidentiality internally

- Kubernetes contains private key and decrypts transparently
- Operator-based approach → reconciliation loop decrypts reprovisioned secret
- Platform-centric



```
kubeseal --format yaml < greeting-secret.yaml \
> greeting-secret_sealedsecrets.yaml -n kubernetes-secrets-sealedsecrets
```

Handling Confidentiality, Summary

All approaches allows you to handle Secrets in Git/SCM:

- Lifecycle, Versioning, Tagging, Part of Release, etc.
- Data is encrypted at rest and decrypted in platform
 - Decryption either takes place externally (Ansible Vault) or internally (Sealed Secret, Helm Secrets)

External platforms might externalize your pain but will increase the complexity massively:

- Attack on the platform might gain partial access anyhow
- Secret management platforms are Single Point of Failures (regarding security and availability)

Secrets in the Platform

If you have access to the platform, you have access to the secrets:

Do never provision your own private keys into the platform. Use dedicated personal keys instead.

Encryption of etcd at rest does not protect (but does protect your backup of the etcd though).

<https://www.macchaffee.com/blog/2022/k8s-secrets/>

